

Phase 3: Risk Assessment and CIS Control Mapping

Startup Security Baseline Audit Framework - Controlled DVWA Laboratory Assessment

Audit scope: Network Exposure, Transport Security, Web Application Layer, Identity and Access, Cloud / Storage.

Ratings basis: Each weakness is rated as if the same setup were an internet-facing production application holding real customer data. DVWA is the test bed. Actual exposure in this lab is limited to 127.0.0.1: Docker publishes DVWA only on 127.0.0.1:4280. DVWA is intentionally vulnerable, so findings tied to its default credentials are demonstration findings, not a defect in the DVWA project.

Test environment: Ubuntu 24.04.1 LTS on WSL2; Docker 29.1.3 running DVWA (ghcr.io/digininja/dvwa) and a MariaDB 10 container; Nmap 7.94SVN; Burp Suite Community v2026.8; testing on 18 Sep 2026. The DVWA security cookie was set to *impossible* during testing.

1. Risk Rating Methodology

Risk = Likelihood x Impact. Likelihood and impact are Low, Medium, or High. The resulting rating is Low, Medium, High, or Critical. The same production-hypothetical basis is applied to every finding.

Likelihood / Impact	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	Critical

Status legend: PASS = check satisfied in the assessed scope. FAIL = evidence shows the check is not satisfied. N/A = technology or check not applicable to this lab. NOT DETERMINED = evidence insufficient to establish the condition. OBSERVATION = noteworthy evidence without a demonstrated vulnerability.

2. Checklist Evidence Mapping

A. Network Exposure

Check item	Status	Evidence	CIS v8 / Safeguard
Any ports open beyond expected 80/443?	OBSERVATION	Nmap full-port scan of 127.0.0.1 found 22/tcp (SSH), 4280/tcp (DVWA, the expected application port in this lab) and 42881/tcp (localhost-only containerd listener). The other 65,532 ports were closed. The generic 80/443 wording does not directly apply to this lab.	4 - Secure Configuration / 4.8 (where an unnecessary service is identified)
SSH exposed to 0.0.0.0/0?	NOT DETERMINED	ss shows sshd listening on 0.0.0.0:22 and [::]:22, meaning all interfaces of the lab host. This does not establish a 0.0.0.0/0 network source range or Internet reachability, which depends on firewall and network setup.	4 - Secure Configuration / 4.8 (review unnecessary exposure)
Database ports publicly reachable?	PASS	The database container (MariaDB 10) shows 3306/tcp with no host port mapping in docker ps. 3306 was closed on 127.0.0.1 in the Nmap scan. The container is reachable only on the internal Docker network (172.18.0.3).	4 - Secure Configuration / 4.8
Do service banners disclose software versions?	FAIL	Server: Apache/2.4.68 (Debian) and X-Powered-By: PHP/8.5.10 are returned in normal responses.	4 - Secure Configuration / 4.1; 16 - Application Software Security

B. Transport Security

Check item	Status	Evidence	CIS v8 / Safeguard
TLS 1.0/1.1 enabled?	N/A	No TLS endpoint available; 443/tcp is closed.	3 - Data Protection / 3.10
Weak/deprecated TLS ciphers?	N/A	No TLS endpoint available.	3 - Data Protection / 3.10
HSTS present?	N/A	The application is HTTP-only. HSTS is an HTTPS policy mechanism, so it is not assessable as a separate check here; the underlying issue is F-01.	3 - Data Protection / 3.10

Check item	Status	Evidence	CIS v8 / Safeguard
Certificate valid?	N/A	No HTTPS certificate because 443/tcp is closed.	3 - Data Protection / 3.10

C. Web Application Layer

Check item	Status	Evidence	CIS v8 / Safeguard
CSP present?	FAIL	Content-Security-Policy was not present in curl or Burp responses.	16 - Application Software Security / 16.7
X-Frame-Options present?	FAIL	X-Frame-Options was not present.	16 - Application Software Security / 16.7
X-Content-Type-Options present?	FAIL	X-Content-Type-Options was not present. Referrer-Policy and Permissions-Policy were also absent.	16 - Application Software Security / 16.7
Admin panel exposed without rate limiting/IP restriction?	N/A / NOT ASSESSED	No suitable admin or rate-limit test was available in the DVWA scope.	16 - Application Software Security
Error pages leak server details?	FAIL	A request to a nonexistent page on port 4280 returned a 404 whose Server header and page body both disclose Apache/2.4.68 (Debian) at 127.0.0.1 Port 4280.	4 - Secure Configuration / 4.1; 16 - Application Software Security
Default credentials active?	FAIL (DEMO FINDING)	Authorized login with DVWA's documented default credentials succeeded: POST /login.php returned 302 to index.php and issued a new session cookie. Retained as a demonstration finding.	4.7 - Manage Default Accounts; 5.2 - Use Unique Passwords
HTTP methods unnecessarily enabled?	OBSERVATION	Nmap http-methods reported GET, HEAD, POST, OPTIONS. A direct OPTIONS request to /login.php returned 200 without an Allow header. Presence of these methods alone does not establish a vulnerability.	16 - Application Software Security

D. Identity and Access

Check item	Status	Evidence	CIS v8 / Safeguard
MFA on admin/privileged accounts?	N/A / NOT ASSESSED	DVWA did not provide suitable MFA configuration.	6.5 - Require MFA for Administrative Access
Password complexity enforced?	N/A / NOT ASSESSED	No meaningful password-policy administration interface was available.	5.2 - Use Unique Passwords
Roles/permissions least privilege?	N/A / NOT ASSESSED	No suitable role-management system was available.	6.8 - Define and Maintain Role-Based Access Control
Default credentials?	FAIL (DEMO FINDING)	Default DVWA credentials authenticated; see F-04.	4.7 - Manage Default Accounts; 5.2 - Use Unique Passwords

E. Cloud / Storage

Check item	Status	Evidence	CIS v8 / Safeguard
S3-style buckets public?	N/A	No cloud storage service in scope.	N/A
Bucket/object policies overly permissive?	N/A	No cloud storage service in scope.	N/A

3. Identified Findings

Four findings are retained after merging the HTTP/TLS issue with the related missing Secure cookie attribute, which avoids double-counting the same root cause. Ratings follow the production-hypothetical basis stated above.

ID / Finding	Evidence and rationale	Likelihood	Impact	Risk	CIS v8 / Safeguard
F-01 HTTP-only application and insecure session transport	443/tcp is closed; 4280/tcp serves HTTP. The PHPSESSID cookie is set with HttpOnly and SameSite=Strict but no Secure attribute; the security cookie has neither Secure nor SameSite. In production, traffic and session cookies could be intercepted by an attacker on the network path.	Medium	High	High	3 - Data Protection / 3.10

ID / Finding	Evidence and rationale	Likelihood	Impact	Risk	CIS v8 / Safeguard
F-02 Missing security response headers	CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy were not present. Application-hardening weakness that increases exposure to clickjacking, MIME sniffing and script injection impact.	Medium	Medium	Medium	16 - Application Software Security / 16.7
F-03 Server/PHP version disclosure	Server: Apache/2.4.68 (Debian) and X-Powered-By: PHP/8.5.10 in normal responses, and the Apache version on the 404 page. Disclosure alone does not demonstrate exploitability.	Low	Low	Low	4.1 - Secure Configuration Process; 16 - Application Software Security
F-04 Default credentials accepted (DVWA demonstration)	Authorized login with DVWA's documented default credentials succeeded (302 to index.php). On an internet-facing system, known defaults would give an attacker direct access. Deliberate DVWA weakness, not a claim about DVWA quality.	High	High	Critical	4.7 - Manage Default Accounts; 5.2 - Use Unique Passwords

4. Evidence Mapping

Finding	Evidence	Interpretation
F-01	Nmap: 443/tcp closed, 4280/tcp open. curl -D and Burp show Set-Cookie for PHPSESSID without Secure; security=impossible cookie lacks Secure and SameSite.	One transport-security root cause: the application does not provide HTTPS, and its cookies are not restricted to HTTPS.
F-02	curl header grep and Burp Repeater responses show none of the listed security headers.	Browser-facing hardening headers are absent.
F-03	curl, Nmap http-headers and Burp show Server: Apache/2.4.68 (Debian) and X-Powered-By: PHP/8.5.10; 404 page names Apache/2.4.68.	Application infrastructure version information is exposed.
F-04	Burp Proxy history: POST /login.php returned 302 to index.php with a new session cookie.	Default credentials remain active in an intentionally vulnerable demonstration application.

5. Observations (Not Classified as Vulnerabilities)

Observation	Result
SSH on 0.0.0.0:22 and [::]:22	Not determined as Internet-exposed; the bind address alone does not establish the source network or public reachability.
42881/tcp	Localhost-only containerd listener (127.0.0.1); HTTP query returned 404 as plain text with no Server header; no vulnerability established.
MariaDB 3306/tcp	Not published to the host; closed on 127.0.0.1 in the Nmap scan.
DVWA container binding	Docker publishes DVWA only on 127.0.0.1:4280, which limits actual lab exposure to the local machine.
GET, HEAD, POST, OPTIONS	Reported by Nmap; not automatically a vulnerability.
No HTTPS certificate	N/A because HTTPS was not deployed. Covered by F-01 rather than counted separately.

6. CIS Controls v8 Reference

CIS Controls v8 contains 18 Controls and 153 Safeguards. A Control is the broader security area; a Safeguard is a more specific action. CIS mapping does not by itself establish formal CIS compliance.

No.	CIS Control	Simple meaning
1	Inventory and Control of Enterprise Assets	Know what devices/assets exist.
2	Inventory and Control of Software Assets	Know what software is installed and authorized.
3	Data Protection	Protect sensitive data, including data in transit.
4	Secure Configuration of Enterprise Assets and Software	Use secure configurations and reduce unnecessary exposure.

No.	CIS Control	Simple meaning
5	Account Management	Manage accounts, passwords, and default/dormant accounts.
6	Access Control Management	Control who can access what and manage privileges.
7	Continuous Vulnerability Management	Continuously identify, prioritize, and remediate vulnerabilities.
8	Audit Log Management	Collect and manage logs for investigation and detection.
9	Email and Web Browser Protections	Protect users from email and browser threats.
10	Malware Defenses	Prevent and detect malware.
11	Data Recovery	Maintain and test data recovery.
12	Network Infrastructure Management	Securely manage network infrastructure and services.
13	Network Monitoring and Defense	Monitor and defend network activity.
14	Security Awareness and Skills Training	Train users to recognize and avoid security risks.
15	Service Provider Management	Manage third-party security risks.
16	Application Software Security	Secure applications throughout their lifecycle.
17	Incident Response Management	Prepare for, respond to, and learn from incidents.
18	Penetration Testing	Test security controls against realistic attack techniques.

Safeguards used: 3.10 Encrypt Sensitive Data in Transit; 4.1 Establish and Maintain a Secure Configuration Process; 4.7 Manage Default Accounts; 4.8 Uninstall or Disable Unnecessary Services; 5.2 Use Unique Passwords; 6.5 Require MFA for Administrative Access; 6.8 Define and Maintain Role-Based Access Control; 16.7 Use Standard Hardening Configuration Templates for Application Infrastructure.

Key controls for this project: 3 Data Protection; 4 Secure Configuration; 5 Account Management; 6 Access Control Management; 16 Application Software Security.

7. Phase 3 Summary

Category	Summary
Findings	4 findings: 1 Critical, 1 High, 1 Medium, 1 Low. Rated on a production-hypothetical basis; actual lab exposure is limited to 127.0.0.1.
Merged issue	The HTTP/no-TLS condition and the missing Secure cookie attribute are combined into F-01 to avoid double-counting.
N/A / Not assessed	TLS versions/ciphers/certificate, HSTS as a separate check, MFA, password policy, role management, admin-panel rate limiting, and cloud storage, where the required functionality was not in scope.
Observations	SSH bind address, containerd listener on 42881, HTTP methods, and lack of an HTTPS certificate are treated as observations or N/A unless evidence establishes a security impact.
Primary CIS mappings	CIS 3, 4, 5, 6, and 16.

This deliverable is based on authorized DVWA laboratory evidence and is intended to demonstrate a reusable audit method.